

# Architecture strategies for establishing a security baseline

Applies to Azure Well-Architected Framework Security checklist recommendation:

 Expand table

SE:01 **Establish a security baseline aligned to compliance requirements, industry standards, and platform recommendations. Regularly measure your workload architecture and operations against the baseline to sustain or improve your security posture over time.**

This guide describes the recommendations for establishing a security baseline. A security baseline is a document that specifies your organization's bare minimum security requirements and expectations across a range of areas. A good security baseline helps you:

- Keep your data and systems secure.
- Comply with regulatory requirements.
- Minimize risk of oversight.
- Reduce the likelihood of breaches and subsequent business effects.

Security baselines should be published widely throughout your organization so that all stakeholders are aware of the expectations.

This guide provides recommendations about setting a security baseline that's based on internal and external factors. Internal factors include business requirements, risks, and asset evaluation. External factors include industry benchmarks and regulatory standards.

## Definitions

 Expand table

| Term                    | Definition                                                                                                                         |
|-------------------------|------------------------------------------------------------------------------------------------------------------------------------|
| Baseline                | The minimum level of security affordances that a workload must have to avoid being exploited.                                      |
| Benchmark               | A standard that signifies the security posture that the organization aspires to. It's evaluated, measured, and improved over time. |
| Controls                | Technical or operational controls on the workload that help prevent attacks and increase attacker costs.                           |
| Regulatory requirements | A set of business requirements, driven by industry standards, that laws and authorities impose.                                    |

A security baseline is a structured document that defines a set of security criteria and capabilities that the workload must fulfill in order to increase security. In a more mature form, you can extend a baseline to include a set of policies that you use to set guardrails.

The baseline should be considered the standard for measuring your security posture. The goal should always be full attainment while keeping a broad scope.

Your security baseline should never be an ad-hoc effort. Industry standards, compliance (internal or external) or regulatory requirements, regional requirements, and the cloud platform benchmarks are main drivers for the baseline. Examples include Center for Internet Security (CIS) Controls, National Institute of Standards and Technology (NIST), and platform-driven standards, such as Microsoft cloud security benchmark (MCSB). All of these standards are considered a starting point for your baseline. Build the foundation by incorporating security requirements from the business requirements.

For links to the preceding assets, see [Related links](#).

Create the baseline by gaining consensus among business and technical leaders. The baseline shouldn't be restricted to technical controls. It should also include the operational aspects of managing and maintaining the security posture. So, the baseline document also serves as the organization's commitment to investment toward workload security. The security baseline document should be distributed widely within your organization to ensure there's awareness about the workload's security posture.

As the workload grows and the ecosystem evolves, it's vital to keep your baseline in sync with the changes to ensure the fundamental controls are still effective.

Creating a baseline is a methodical process. Here are some recommendations about the process:

- **Asset inventory.** Identify stakeholders of workload assets and the security objectives for those assets. In the asset inventory, classify by security requirements and criticality. For information about data assets, see [Recommendations on data classification](#).
- **Risk assessment.** Identify potential risks associated with each asset and prioritize them.
- **Compliance requirements.** Baseline any regulatory or compliance for those assets and apply industry best practices.
- **Configuration standards.** Define and document specific security configurations and settings for each asset. If possible, templatize or find a repeatable, automated way to apply the settings consistently across the environment.
- **Access control and authentication.** Specify the role-based access control (RBAC) and multifactor authentication (MFA) requirements. Document what *just enough access*

means at the asset level. Always start with the principle of least privilege.

- **Patch management.** Apply latest versions on all the resource types to strengthen against attack.
- **Documentation and communication.** Document all configurations, policies, and procedures. Communicate the details to the relevant stakeholders.
- **Enforcement and accountability.** Establish clear enforcement mechanisms and consequences for noncompliance with the security baseline. Hold individuals and teams accountable for maintaining security standards.
- **Continuous monitoring.** Assess the effectiveness of the security baseline through observability and make improvements over time.

## Define the baseline

Here are some common categories that should be part of a baseline. The following list isn't exhaustive. It's intended as an overview of the document's scope.

### Regulatory compliance

A workload might be subject to regulatory compliance for specific industry segments, there might be some geographic restrictions, and so on. It's key to understand the requirements as given in the regulatory specifications because those influence the design choices and in some cases must be included in the architecture.

The baseline should include regular evaluation of the workload against regulatory requirements. Take advantage of the platform-provided tools, such as Microsoft Defender for Cloud, which can identify areas of noncompliance. Work with the organization's compliance team to make sure all requirements are met and maintained.

### Architecture components

The baseline needs prescriptive recommendations for the main components of the workload. These usually include technical controls for networking, identity, compute, and data. Reference the security baselines provided by the platform and add the missing controls to the architecture.

Refer to [Example](#).

### Development processes

The baseline must have recommendations about:

- System classification.
- The approved set of resource types.
- Tracking the resources.
- Enforcing policies for using or configuring resources.

The development team needs to have a clear understanding of the scope for security checks. For example, threat modeling is a requirement in making sure that potential threats are identified in code and in deployment pipelines. Be specific about static checks and vulnerability scanning in your pipeline and how regularly the team needs to perform those scans.

For more information, see [Recommendations on threat analysis](#).

The development process should also set standards on various testing methodologies and their cadence. For more information, see [Recommendations on security testing](#).

## Operations

The baseline must set standards on using threat detection capabilities and raising alerts on anomalous activities that indicate actual incidents. Threat detection needs to include all layers of the workload, including all the endpoints that are reachable from hostile networks.

The baseline should include recommendations for setting up incident response processes, including communication and a recovery plan, and which of those processes can be automated to expedite detection and analysis. For examples, see [Security baselines for Azure overview](#).

The incident response should also include a recovery plan and the requirements for that plan, such as resources for regularly taking and protecting backups.

You develop data breach plans by using industry standards and recommendations provided by the platform. The team then has a comprehensive plan to follow when a breach is discovered. Also, check with your organization to see if there's coverage through cyberinsurance.

## Training

Develop and maintain a security training program to ensure the workload team is equipped with the appropriate skills to support the security goals and requirements. The team needs fundamental security training, but use what you can from your organization to support specialized roles. Role-based security training compliance and participation in drills are part of your security baseline.

# Apply the baseline

Use the baseline to drive initiatives, such as:

- **Preparedness toward design decisions.** Create the security baseline and publish it before you start the architecture design process. Ensure team members are fully aware of your organization's expectations early, which avoids costly rework caused by a lack of clarity. You can use baseline criteria as workload requirements that the organization has committed to and design and validate controls against those constraints.
- **Measure your design.** Grade the current decisions against the current baseline. The baseline sets actual thresholds for criteria. Document any deviations that are deferred or deemed long-term acceptable.
- **Drive improvements.** While the baseline sets attainable goals, there are always gaps. Prioritize the gaps in your backlog and remediate based on prioritization.
- **Track your progress against the baseline.** Continuous monitoring of security measures against a set baseline is essential. Trend analysis is a good way of reviewing security progress over time and can reveal consistent deviations from the baseline. Use automation as much as possible, pulling data from various sources, internal and external, to address current issues and prepare for future threats.
- **Set guardrails.** Where possible, your baseline criteria must have guardrails. Guardrails enforce required security configurations, technologies, and operations, based on internal factors and external factors. Internal factors include business requirements, risks, and asset evaluation. External factors include benchmarks, regulatory standards, and threat environment. Guardrails help minimize the risk of inadvertent oversight and punitive fines for noncompliance.

Explore Azure Policy for custom options or use built-in initiatives like CIS benchmarks or Azure Security Benchmark to enforce security configurations and compliance requirements. Consider creating Azure Policies and initiatives out of baselines.

## Evaluate the baseline regularly

Continuously improve security standards incrementally towards the ideal state to ensure continual risk reduction. Conduct periodic reviews to ensure that the system is up-to-date and in compliance with external influences. Any change to the baseline must be formal, agreed upon, and sent through proper change management processes.

Measure the system against the new baseline and prioritize remediations based on their relevance and effect on the workload.

Ensure that the security posture doesn't degrade over time by instituting auditing and monitoring compliance with organizational standards.

## Azure facilitation

The Microsoft cloud security benchmark (MCSB) is a comprehensive security best practice framework that you can use as a starting point for your security baseline. Use it along with other resources that provide input to your baseline.

For more information, see [Introduction to the Microsoft cloud security benchmark](#).

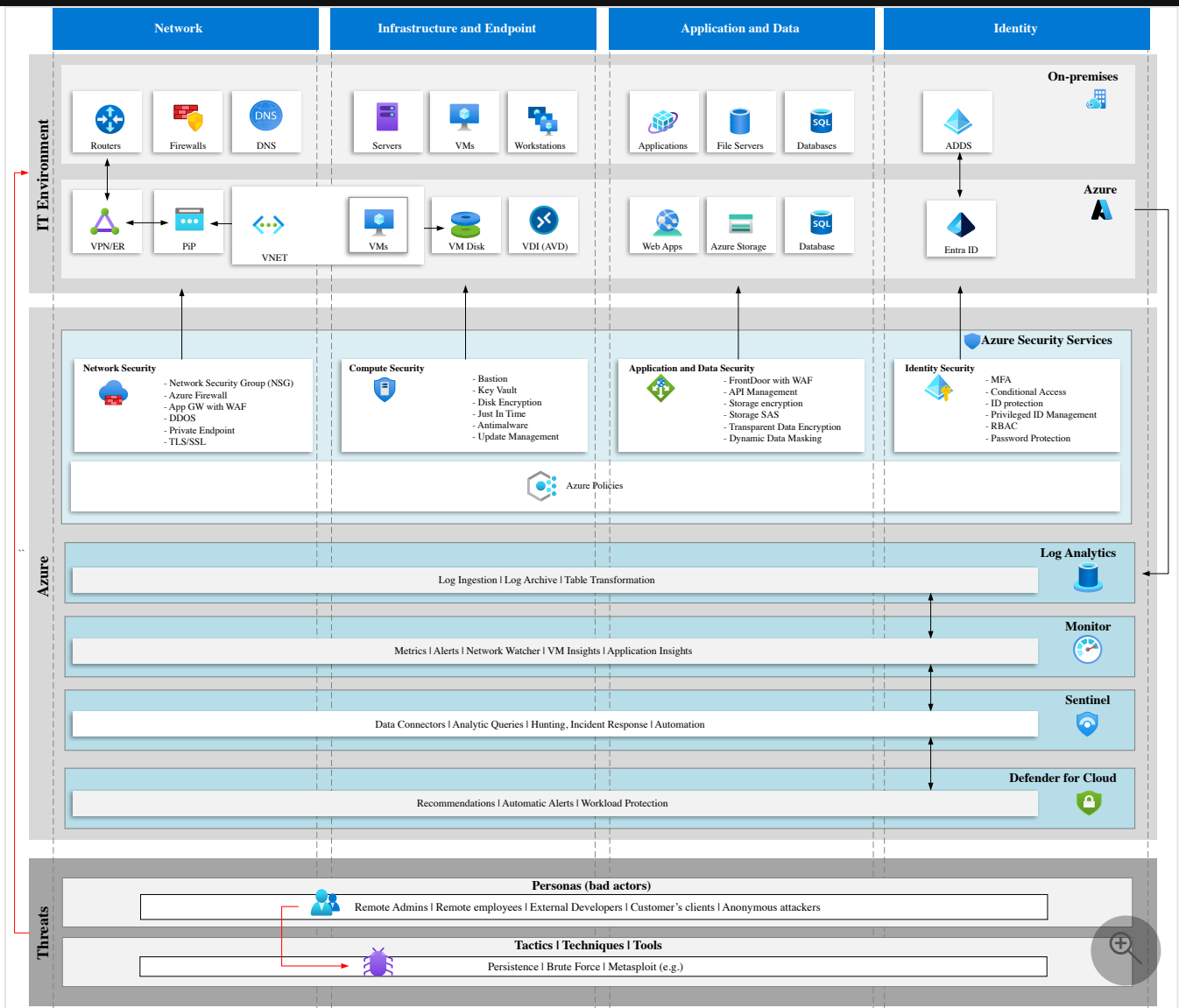
Use the Microsoft Defender for Cloud (MDC) regulatory compliance dashboard to track those baselines and be alerted if a pattern outside of a baseline is detected. For more information, see the [Customize the set of standards in your regulatory compliance dashboard](#).

Other features that help in establishing and improving the baseline:

- [Create custom Azure security policies](#)
- [Understand security policies, initiatives, and recommendations](#)
- [Regulatory compliance checks](#)

## Example

This logical diagram shows an example security baseline for architectural components that encompass network, infrastructure, endpoint, application, data, and identity to demonstrate how a common IT environment may be securely protected. Other recommendation guides build on this example.



## Infrastructure

A common IT environment, with an on-premises layer with basic resources.

## Azure Security services

Azure security services and features by the types of resources they protect.

## Azure security monitoring services

The monitoring services available on Azure that go beyond simple monitoring services, including security information event management (SIEM) and security orchestration automated response (SOAR) solutions and Microsoft Defender for Cloud.

## Threats

This layer brings a recommendation and reminder that threats may be mapped according to your organization's concerns regarding threats, regardless of the methodology or matrix-like Mitre Attack Matrix or Cyber Kill chain.

## Related links

- [Microsoft compliance](#)
- [Security baselines for Azure overview](#)
- [What is incident response? Plan and steps](#) 
- [Azure Security benchmarks](#)

## Community links

- [CIS Microsoft Azure Foundations Benchmark](#) 
- [Cybersecurity framework | NIST](#) 

## Security checklist

Refer to the complete set of recommendations.

[Security checklist](#)

---

Last updated on 11/14/2023